Campus Companion: Ethics Statement

- **Team Members:** Kaden Sawyer and Laila Raines

Privacy summary

Data item	Source	Purpose	Consent	Storage	Access	Retention
Account email and password	Student sign-up (Supabase Auth)	Sign in	Checkbox that states "by creating an account, you agree to our Terms of Service and Privacy Policy", with link to policy	`auth.users` (Supabase Auth)	app doesn't store password (will be hashed through Supabase), email access is only the server and us through a user list	Keep info until user deletes account or until given graduation date
Consent record (`student.consented_at`)	Student, consent screen	courses cannot be saved until set	"Allow" button asking permission to student info	`student` table (Supabase)	Server only (row-level security on, no policies)	Deleting account removes all data, if consent is withdrawn all data is deleted
Uploaded schedule PDF (I1)	Student upload, 10 MB max	Extract courses for review	Student is told that the PDF is read to extract courses and then will discard the file	discarded after extraction	only server with request can read the file	discarded after extraction is finished
Course records (name, professor, building, room, days, times, term dates)	Extracted from PDF or manual entry, confirmed by student	Walking times (C2) and event fit (C3)	"Allow" checkbox for permission to store course info	`course` table (Supabase)	Server only (row-level security)	deleted when student deletes their account and 30 days after the end of the course
Interests, including identity-based categories	Student onboarding	Event matching (C3) and	Optional selection stating that it will	`student_interest` table	Server only (row-level security)	Deleted after account is deleted,

Data item	Source	Purpose	Consent	Storage	Access	Retention
		notifications (C7)	search for clubs of possible interest			after student removes interest, and after graduation date
Club record (name, head, `verified_at`)	Club head form (I7), admin approval	Verify the club before it can post	"Agree" checkbox stating that the status will be collected and reviewed against Campus Links and the info is kept if verified.	`club` table	Server writes, students will see the name, club head can edit (club head verified through campus link, and must be signed in to edit)	deleted if club head requests removal, club is inactive for a year, or head of the club account is deleted
Club verification request and admin notes	Club head; admin checks UC organization list (I12)	Manual club approval (D-04)	"Agree" checkbox stating that the club info will be collected and reviewed against Campus Links and the info is kept if verified	Stores the request and outcome (denied or approved)	club head can view status, admins see the request and the corresponding email	pending request expire after 30 days, denied requests delete after notification to club head
Event posts (name, building, room, description, times, status, categories)	Club head (I7, I9)	Event list and notifications	"Allow" checkbox stating that event information will be stored unless event is cancelled	`event`, `event_category` tables	Published events visible to students	Data is deleted 1 week after the event ends, 1 week after the cancelled event, or when the club is removed
Notification content and device token (I11)	System and student's phone	Notify interested students	"Allow" checkbox asking users if	student and device token (push_device) and queued notices (notification_job)	server access, interested students will	data deleted after 30 days,

Data item	Source	Purpose	Consent	Storage	Access	Retention
			they would like to receive updates on events of interest	tables in Supabase. Notices also pass through Expo's push service to reach Apple or Google.	receive their notification	deleted if club is deleted. Device token deleted when the student signs out, deletes their account, or the push service reports it invalid
Server and API logs	Server	Debugging and security	Information disclosed in privacy notice prior to creating login, proceed option given	The hosting provider's log storage for our server, plus Supabase's dashboard logs. Not stored in our git repository or database tables	team members only	based on host's default (will confirm timeframe later)
Campus buildings, paths, and walk times (not personal)	OpenStreetMap (I5)	Routing	n/a	`building`, `walk_time` tables	Server	Refreshed on each map import

- **What happens to the data when the project ends:** We will delete stored real data like clubs, schedules, interests, etc after our showcase, but may keep a few fictional accounts for future viewing
- **Fields removed because we could not justify them:** No fields needed to be removed from current version

Security summary

- **Authentication:** Supabase Auth email and password sign-in. Every request carries `Authorization: Bearer <access token>` over HTTPS.
- **Token lifetime:** The access token is valid for 1 hour and is renewed with a refresh token.
- **Database:** Row-level security is on for every table with no policies. Only the server's secret key can read or write data, and the public key in the apps cannot.
- **Uploads:** PDF only, 10 MB maximum.
- **Where secrets live:** The Supabase secret key and other server credentials will be stored as environment variables in the hosting provider's settings, not in the repository. The apps contain only the public key, and `.env` files are listed in `.gitignore`.
- **HTTPS enforcement:** The app calls the API over HTTPS (D1 Part 5).
- **Rate limiting:** Supabase Auth applies its own limits to sign-in and sign-up requests by default. No custom rate limiting is applied to our own API endpoints, as we are using the free tiers to stay within our budget.
- **Git history search results:**
- Ran gitleaks on all branches of the repository on 2026-11-12. 25 commits were scanned and no leaks were found

Common capstone gap	How we will address it
Default credentials	We will give the Supabase dashboard, hosting dashboard, and admin account unique passwords with two-factor sign-in where available, and we will not create seeded or shared accounts.
Unauthenticated endpoints	Every API route will require a Supabase access token and return 401 `not_signed_in` without one, as D1 Part 5 specifies. We will test each route without a token before release and disable or protect FastAPI's `/docs` routes.
Secrets in source control	The Supabase secret key and other credentials will live only in the host's environment variables, and `.env` will stay in `.gitignore`. Ran gitleaks on full history of the repo and found no leaks. We will rerun it before the release

Self-audit questions

Question	Our answer
Can a student read another student's schedule?	No, the API returns only the info of the student signed in
Does any API route work without signing in?	No. Every /v1 route requires a Supabase access token
Can the app read or write to the database directly?	No, only the server's secret key has access
Are passwords stored by us?	No, Supabase Auth hashes and stores them

Licensing summary

Name	Version	License (SPDX)	Permissive or copyleft	Obligation
Supabase (hosted platform)	n/a (hosted service)	Apache-2.0	Permissive	Used as a hosted service under Supabase's terms. Apache-2.0 notices apply only if we redistribute its code.
PostgreSQL (through Supabase)	Set by Supabase (will confirm later)	PostgreSQL	Permissive	Keep the copyright notice and license text if redistributed.
Supabase Auth (hosted)	n/a (hosted service)	MIT	Permissive	Keep the copyright and license notice if redistributed.
supabase-py	2.34.0	MIT	Permissive	Keep the copyright and license notice.
FastAPI	0.162.0	MIT	Permissive	Keep the copyright and license notice.
Pydantic	2.14.3	MIT	Permissive	Keep the copyright and license notice.
Uvicorn	0.54.0	BSD-3-Clause	Permissive	Keep the copyright notice and license. Do not use the authors' names to endorse our project.
pdfplumber	0.11.10	MIT	Permissive	Keep the copyright and license notice.
OSMnx	2.1.1	MIT	Permissive	Keep the copyright and license notice.
NetworkX	3.7	BSD-3-Clause	Permissive	Keep the copyright notice and license. Do not use the authors'

Name	Version	License (SPDX)	Permissive or copyleft	Obligation
				names to endorse our project.
React Native	0.85.0	MIT	Permissive	Keep the copyright and license notice.
React	19.3.0	MIT	Permissive	Keep the copyright and license notice.
Vite	8.3.7	MIT	Permissive	Keep the copyright and license notice.
Python standard library	Python 3.13.7	PSF-2.0	Permissive	Keep the PSF license notice if redistributed.
OpenStreetMap data	will be downloaded in January	ODbL-1.0	Copyleft (share-alike, applies to the data)	Show "© OpenStreetMap contributors" with a link to the license wherever the map or routes appear. A publicly used derivative database must also be offered under ODbL.
Expo Push Service (hosted)	n/a (hosted service)	Proprietary, free to use	n/a	Used under Expo's terms. We send only public event information.
expo-notifications	Selected when project is setup	MIT	Permissive	Keep the copyright and license notice.
httpx	Selected when project is setup	BSD-3-Clause	Permissive	Keep the copyright notice and license.
MapLibre React Native	Selected when project is setup	MIT	Permissive	Keep the copyright and license notice.
MapLibre GL JS	Selected when project is setup	BSD-3-Clause	Permissive	Keep the copyright notice and license. Do not use the authors' names to endorse our project.
OpenFreeMap (hosted background map)	n/a (hosted service)	MIT. Map data is OpenStreetMap, ODbL-1.0.	Service is permissive. Map data is copyleft (see OpenStreetMap row).	Show the attribution "OpenFreeMap © OpenMapTiles Data from OpenStreetMap." MapLibre adds it automatically. Showing the OpenFreeMap part is optional

- **Our project's license:** MIT, as we may share our code and a permissive license matches the licenses of our dependencies.
- **Compatibility with every row:** Every code dependency is permissive (MIT, BSD-3-Clause, Apache-2.0, PostgreSQL, or PSF-2.0), and the hosted services (Supabase, Expo, OpenFreeMap) are used under their own terms, so MIT is compatible with all of them
- **Copyleft items and what we decided:** The only copyleft item is the OpenStreetMap data, which also reaches the apps through OpenFreeMap's background map. We keep our building and walk_time tables private on our own server. We serve only individual routes to signed-in students and never release the full tables, so the share-alike requirement for a publicly used derivative database is not triggered. We show "© OpenStreetMap contributors" with a link to the license wherever the map or routes appear. We also evaluated PyMuPDF and rejected it in favor of pdfplumber

Attribution list

- This section is also placed in NOTICE.md
    - **Libraries (source URLs):**
        - Supabase: https://github.com/supabase/supabase

    - Supabase Auth: https://github.com/supabase/auth
    - supabase-py: https://github.com/supabase/supabase-py
    - PostgreSQL: https://www.postgresql.org
    - FastAPI: https://github.com/fastapi/fastapi
    - Pydantic: https://github.com/pydantic/pydantic
    - Uvicorn: https://github.com/Kludex/uvicorn
    - pdfplumber: https://github.com/jsvine/pdfplumber
    - OSMnx: https://github.com/gboeing/osmnx
    - NetworkX: https://github.com/networkx/networkx
    - React: https://github.com/facebook/react
    - React Native: https://github.com/facebook/react-native
    - Vite: https://github.com/vitejs/vite
    - Python: https://www.python.org
    - Expo: https://github.com/expo/expo
    - httpx: https://github.com/encode/httpx
    - MapLibre React Native: https://github.com/maplibre/maplibre-react-native
    - MapLibre GL JS: https://github.com/maplibre/maplibre-gl-js
    - OpenFreeMap: https://openfreemap.org
  - **Code adapted from tutorials or other repositories (source named):** None currently
  - **Datasets (collection method, usage restrictions):** OpenStreetMap campus buildings and paths for UC's Uptown West campus, will be downloaded in January with OSMnx and stored in the building and walk_time tables. Usage of ODbL 1.0 requires the attribution "© OpenStreetMap contributors" with a link to openstreetmap.org/copyright wherever the data or routes are shown, plus share-alike for a publicly used derivative database. The apps also load background map from OpenFreeMap at runtime, which carry OpenStreetMap data and the attribution shown in the Licensing summary
  - **Non-code assets (author, license):** None

AI-use disclosure

- Syllabus AI policy: "Generative AI tools may be used for drafting and code assistance but not for the design decisions or written analysis that are assessed in this course."

Tool	Used by	Task	Column	How verified
Claude	Laila	Assignment 3 ran essay to check for grammatical errors and gaps in the ask	Generally ok	Reviewed results and adjusted accordingly
Claude	Kaden and Laila	For Assignment 4: Ran user stories to verify validity and assist in adjusting to fit requirements	Generally ok	reviewed results and adjusted accordingly
Claude	Kaden	For Assignment 5: Showed completed diagram and version of md. Asked for adjustments to complete requirements	Generally ok	reviewed results and adjusted accordingly
Claude	Kaden	For Assignment 6: Showed completed diagram and version of md. Asked for adjustments to complete requirements	Generally ok	reviewed results and adjusted accordingly
Claude	Laila	Outlined Assignment 11, suggested commands for the git-history search and license inventory, explained how consent, access, and retention are usually handled for each data item, suggested wording for the Security, Licensing, and Attribution sections. Provided the code to search git history	Generally ok	Checked for inconsistencies and adjusted accordingly

We confirm that the architecture, data model, priorities, and design rationale were the team's own.

- Laila Raines
- Kaden Sawyer